

AtlasGrid - Chronologie d'incident MIRAGE

Version consolidée - éléments horodatés, pièces sourcées et décisions de crise

Incident Rançongiciel MIRAGE	Impact 23 serveurs chiffrés sur 40	Exfiltration établie 117,8 Go	Reprise décidée Copie LTO-9 hors ligne
---------------------------------	---------------------------------------	----------------------------------	---

Lecture prudente : les repères J sont ceux des pièces source. Le volume de 117,8 Go est objectivé par les journaux proxy. Les 300 Go annoncés par SIROCCO restent une revendication non confirmée.

1. Chaîne d'attaque reconstituée

Moment	Fait établi	Pièce
J-21 à J-1 02:00-05:00	Sessions VPN anormales du compte prestataire svc_oasisnet : hors horaires, sans MFA, IP incompatibles avec le profil attendu.	Preuve A-02, A-10
J-11 02:03	Création de la règle pare-feu OUT-TEMP-443 depuis FIN-112 vers HTTPS, avec journalisation désactivée.	Preuve A-09
J-10 à J-1 nuits	Transferts de FIN-112 puis FILER-RBT vers 45.137.184.62:443 : total objectivé de 117,8 Go.	Preuve A-03
J-3 01:12	Modification de la rétention des sauvegardes par svc_oasisnet. Les travaux J-3, J-2 et J-1 sont exclus.	Preuve A-05
J-1 03:11-03:12	Privilèges spéciaux pour svc_oasisnet. Sur FIN-112, lancement de svhost32.exe, binaire non signé ; la quarantaine Defender échoue.	Preuve A-01, A-10, A-12
J-1 03:12-03:16	Désactivation de Defender, lecture de 9 412 fichiers, C2, chiffrement de 14 partages en .mirage et suppression de VSS / catalogue de sauvegarde.	Preuve A-01, A-09, A-12
J-1 03:15:39	Création de LISEZMOI_MIRAGE.txt sur FILER-RBT-02. Les métadonnées NTFS révèlent une incohérence de dates.	Preuve A-04
J1 15:28	BKP-01 et BKP-02 deviennent injoignables. La restauration en ligne n'est plus une option fiable.	Preuve A-05
J1 06:41:22	Réception d'un phishing atlasgrid-it.info : SPF / DKIM / DMARC défaillants et lien de saisie d'identifiants. Lien causal avec MIRAGE non établi.	Preuve A-11
J2 10:00	Inventaire : 23 serveurs chiffrés sur 40, dont paie, facturation, ERP et fichiers. OT/SCADA isolé et intact.	Preuve A-13
J2 10:15	Tentative de fraude au président bloquée : 480 000 MAD. Incident financier distinct de MIRAGE.	Preuve A-23

Moment	Fait établi	Pièce
J2 15:20	SIROCCO publie un échantillon de données clients et contractuelles. L'exposition est corroborée ; 300 Go restent non confirmés.	Preuve A-07

2. Décisions de crise et reprise

Moment	Décision / étape	Motif et effet	Référence
Acte I	Isoler FIN-112 sous tension	Stopper la propagation tout en préservant mémoire, processus et traces volatiles.	Décision 01
Acte I	Isoler les segments critiques	Bloquer les flux à risque et préserver uniquement les services indispensables, sous contrôle.	Décision 02
Acte II	Communiquer en interne	Donner des consignes sans divulguer de détails sensibles ni promettre une absence d'impact.	Décision 03
Acte II	Maintenir l'OT sous surveillance	L'OT est isolé et non compromis. Les critères de coupure sont préparés, sans coupure préventive disproportionnée.	Décision 04
Acte II	Déclarer l'assureur	Préserver la couverture, les preuves et le cadre de réponse.	Décision 05
Acte II	Répondre aux clients, presse et Autorité	Message factuel, notification évolutive et absence de promesse non démontrée.	Décisions 06-08
J3 09:30	Inventorier les sauvegardes	En ligne : hors service depuis J-3. Hors ligne : bandes LTO-9 de Settât, dernière copie J-42, jamais testée.	Preuve A-06
J3	Vérifier les points en ligne	RP-J-2 est sain ; RP-J-1 est suspect et RP-J-0 infecté. Restaurer les deux derniers points réintroduirait MIRAGE.	Preuve A-30
J3 11:00	Décider de ne pas payer	Aucune garantie de déchiffrement ou d'effacement. La cellule choisit la reprise hors ligne sans financer l'extorsion.	Décision Direction

3. Plan de reprise depuis Settât

Horizon	Étape	Condition / effet
J+0	Acheminement des bandes LTO-9	Coffre de Settât vers datacenter ; conservation de l'air-gap.
J+1	Restauration annuaire (AD)	Priorité à l'authentification dans un environnement reconstruit et contrôlé.
J+2 à J+4	Restauration ERP et base	Remise en route du coeur métier après validation technique.
J+4 à J+6	Paie et facturation	Services sensibles remis progressivement.
J+6 à J+9	Partages de fichiers	Volumes importants et vérifications complémentaires.

Limites à communiquer : perte estimée de six semaines de données (dernière copie J-42) ; ETA complète de 5 à 10 jours, à confirmer par les tests de restauration. Aucune reprise ne doit intervenir avant fermeture de l'accès initial et validation d'un environnement sain.

4. Fausses pistes et bruits écartés

Les éléments suivants ne sont pas supprimés : ils démontrent une méthode de triage. Ils ne doivent pas être présentés comme des causes de MIRAGE.

Statut	Élément	Pourquoi il est écarté
Fausse piste	A-19 - clé USB du parking	Jamais connectée au SI ; aucun lien exploitable.
Fausse piste	A-20 - courriel de migration	Courriel interne légitime, vérifié.
Fausse piste	A-14 / A-17 - badge et USB paie	Lecteur de badge non fiable ; copie USB de paie autorisée.
Fausse piste	A-16 / A-15 / A-24 / A-18	Pic presse, jeton d'ex-salarié, salarié en litige et DarkAtlas investigués puis écartés.
Bruit	A-21 / A-25 / A-27	Scans Internet, PsExec de maintenance et archivage trimestriel : activités attendues ou sans lien.
Bruit	A-26 / A-40 / A-41 / A-22	Connexion Paris, ticket OasisNet d'un autre client, assistance distante et faux positif CoinMiner : pas de corrélation MIRAGE.
Bruit	A-28 - compte svc_backup	Sauvegarde Veeam nocturne planifiée depuis VBR-01, profil identique depuis des mois.
Bruit	A-31 - macro sur DG-01	Alerte J-90, déjà nettoyée, sans connexion réseau ni lien avec le C2.
Bruit	PUA FIN-112 et vague de spam	Alertes anciennes ou commerciales, sans corrélation technique avec l'incident.
Fausse piste	Wi-Fi invité / caméras	Wi-Fi isolé sans accès serveurs ; caméras en panne, donc aucune image exploitable.

5. Conclusion de la cellule

La chaîne la plus étayée est : accès anormaux svc_oasisnet - règle de sortie - exfiltration et sabotage des sauvegardes - exécution sur FIN-112 - chiffrement MIRAGE - impact métier et exposition corroborée. La reprise est conduite depuis la copie hors ligne de Settat, avec un retour progressif et sans paiement de rançon.

Références principales : A-01, A-02, A-03, A-04, A-05, A-07, A-09, A-10, A-11, A-12, A-13, A-23, A-06 et A-30.